

Small Business Security Pro Toolkit

A practical operating toolkit for small businesses, freelancers, and non-technical teams. Build a repeatable security baseline instead of relying on guesswork.

Included: 18 working sections, checklists, policy starters, worksheets, risk register, access review, incident plan, and 90-day roadmap

Aligned in structure with the risk-management mindset of NIST CSF 2.0 and practical small-business guidance. This is an implementation aid, not a certification.

1. How to use this toolkit

NIST CSF 2.0 is designed to help organizations of any size manage cybersecurity risk, and NIST provides small-business quick-start guidance specifically for organizations with modest or no cybersecurity plans. Use this toolkit as a simpler implementation worksheet built around that same risk-management mindset. ■

Start with the highest-value controls

- Secure critical accounts and enable MFA where available.
- Establish a reliable backup and restoration process.
- Patch operating systems, browsers, and important applications.
- Create a clear phishing/suspicious-message reporting route.
- Limit administrative access and remove stale accounts.
- Write down what to do when something goes wrong.

Security owner

Owner/role: _____ Review cadence: _____

2. Business security snapshot

Use this page to identify what matters before choosing controls. The goal is to understand the systems, data, people, and dependencies that would most affect your business if disrupted or compromised.

Question	Answer
What are our 3 most critical business processes?	_____
What systems support them?	_____
What data would cause the most harm if exposed or lost?	_____
Which accounts would be catastrophic to lose?	_____
Which vendor/service could stop operations if unavailable?	_____

Top three business priorities

1. _____
2. _____
3. _____

3. Critical account security

Prioritize email, domain/DNS, cloud storage, finance/payment systems, social media, admin consoles, and any account that can reset other accounts.

- Unique credentials are used for important accounts.
- MFA is enabled on critical accounts where supported.
- Recovery methods are current and controlled by the business.
- Shared credentials are minimized and replaced with individual accounts where possible.
- Administrative access is separated from everyday accounts.
- Former staff and contractors have been removed.
- Login/security alerts are enabled for important accounts.
- A documented owner exists for critical accounts.
- Domain and DNS administration is known and protected.
- Account access is reviewed at least periodically.

Critical account inventory

Account/system	Owner	MFA	Recovery	Last review
_____	_____	Yes/No	_____	_____
_____	_____	Yes/No	_____	_____
_____	_____	Yes/No	_____	_____
_____	_____	Yes/No	_____	_____

4. Password & authentication standard

Use a password manager where appropriate, prefer long unique passwords, and focus on phishing-resistant authentication for high-value accounts when available. Avoid arbitrary complexity rules that encourage predictable password changes; change credentials when compromise is suspected or access conditions change.

- Password reuse is prohibited for critical accounts.
- Passwords are not shared through ordinary chat or email.
- MFA is required for critical accounts whenever available.
- Authentication recovery methods are protected and reviewed.
- Administrator credentials are not used for routine browsing/email.
- Suspected-compromise credentials are reset promptly.
- Access is revoked when staff leave or roles change.

Internal policy wording

Our organization requires _____. Sensitive requests must be verified by _____.

Password manager / authentication platform

Tool: _____ Owner: _____

5. Device security baseline

Apply the baseline to company laptops, desktops, mobile devices, and any personal device formally allowed to access business information.

- Automatic operating-system updates are enabled.
- Browsers and major applications are kept current.
- Screen lock is enabled and activates automatically.
- Device login uses strong authentication.
- Disk encryption is enabled where supported and appropriate.
- Endpoint security/antimalware is enabled where appropriate.
- Unneeded software and browser extensions are removed.
- Local administrator privileges are limited.
- Lost/stolen device procedures are documented.
- Business data is not unnecessarily copied to unmanaged devices.

Device inventory sample

Device	User	OS	Encryption	Admin rights
_____	_____	_____	Yes/No	Yes/No
_____	_____	_____	Yes/No	Yes/No
_____	_____	_____	Yes/No	Yes/No

6. Backup & recovery plan

A backup strategy should cover what to protect, where copies are stored, how often backups run, and how restoration will be tested.

- Critical data has been identified.
- Backups run on a defined schedule.
- At least one copy is separated from everyday access where practical.
- Backup access is itself protected with strong authentication.
- Restoration has been tested on representative files.
- Someone owns the recovery process.
- Recovery priorities and acceptable downtime are documented.

Recovery worksheet

System/data	Priority	Backup location	Last restore test
_____	High/Med/Low	_____	_____
_____	High/Med/Low	_____	_____
_____	High/Med/Low	_____	_____
_____	High/Med/Low	_____	_____

7. Email & phishing defense

CISA small-business resources emphasize phishing avoidance, passwords, MFA, software updates, logging, backups, and encryption as practical security foundations. Use the following as an operational checklist, then adapt it to your environment. ■

- Unexpected payment or bank-detail changes are verified through a second trusted channel.
- Unexpected attachments are treated cautiously.
- Users know how to report suspicious messages.
- Email accounts use MFA where supported.
- High-risk requests require independent verification.
- Staff understand that familiar names can be spoofed or accounts compromised.
- For owned domains, SPF/DKIM/DMARC are reviewed as appropriate.

Verification rule

No payment, password reset, bank-detail change, or sensitive-data request is approved solely because it arrived by email or chat.

8. Access control & joiner/leaver process

Least privilege is a practical objective: people should have the access they need for their role, and no more than they need.

- Maintain a list of users and systems they can access.
- Use individual accounts whenever practical.
- Review administrator privileges.
- Remove access immediately when someone leaves.
- Adjust access when responsibilities change.
- Review third-party application connections.
- Document who approves sensitive access.

Joiner / leaver checklist

Event	Required actions
New joiner	Create account; assign minimum access; enable MFA; provide security guidance.
Role change	Review permissions; remove old access; record approval.
Leaver	Disable accounts; revoke sessions/tokens; recover devices; transfer business data safely.

9. Incident response mini-plan

When something suspicious happens, slow down, contain the problem, preserve useful information, and communicate clearly. Legal, regulatory, contractual, and insurance obligations may apply depending on the incident and jurisdiction.

Immediate sequence

- 1. Identify what happened and what may be affected.
- 2. Contain the affected account/device/system where safe and appropriate.
- 3. Preserve relevant emails, screenshots, timestamps, and logs.
- 4. Secure credentials from a trusted environment when compromise is suspected.
- 5. Notify the designated decision-maker.
- 6. Determine whether customers, partners, counsel, insurers, regulators, or authorities need to be involved.
- 7. Recover safely and document lessons learned.

Incident contacts

Role	Name	Contact
Security owner	_____	_____
Business owner	_____	_____
IT/support	_____	_____
Legal/compliance	_____	_____

10. Incident worksheet

Date/time discovered: _____

Reported by: _____

Affected system/account/device: _____

What happened? _____

Immediate containment: _____

Credentials changed/revoked? Yes / No

Evidence preserved? Yes / No

Who was notified? _____

Potential customer/partner impact: _____

Follow-up actions: _____

11. Third-party & cloud security review

Your security depends on services you use. Focus on vendors that store sensitive data, control important accounts, process payments, or are necessary for business continuity.

- List critical SaaS and cloud services.
- Review admin accounts and MFA settings.
- Know what information each vendor holds.
- Remove obsolete integrations and API connections.
- Keep account recovery and billing contacts current.
- Understand how to recover/export essential data.
- Review security/privacy documentation for critical vendors.
- Document shared responsibilities where practical.

Vendor/service	Business critical?	Data held	Owner	Review date
_____	Yes/No	_____	_____	_____
_____	Yes/No	_____	_____	_____
_____	Yes/No	_____	_____	_____

12. Security awareness & training

Training should be short, practical, and repeated. Teach people what to do, not just what threats exist.

- Everyone knows the official route for reporting suspicious messages.
- Payment and sensitive-data requests require verification.
- New staff receive security onboarding.
- High-risk roles receive additional guidance.
- Phishing examples are reviewed periodically.
- People know how to report lost/stolen devices or accidental disclosure.
- Training attendance and completion are documented where appropriate.

30-minute team briefing agenda

10 min: phishing examples 5 min: MFA/passwords 5 min: lost devices 5 min: reporting process 5 min: questions

13. One-page employee security policy starter

Employees must: use unique credentials; enable required MFA; lock devices; install approved updates; treat unexpected links/attachments/payment requests cautiously; report suspected incidents quickly; and use approved systems for business data.

Employees must not: share passwords; bypass security controls without authorization; install unapproved software; send sensitive business data to personal accounts without approval; or ignore a suspected security event.

Company-specific rules

14. Security scorecard

This scorecard is an internal prioritization tool, not a certification. Score each domain 0-10 based on how consistently the control is implemented and maintained.

Domain	Score (0-10)	Next improvement
Governance / ownership	_____	_____
Critical accounts	_____	_____
Devices	_____	_____
Backups / recovery	_____	_____
Email / phishing	_____	_____
Access control	_____	_____
Incident response	_____	_____
Third parties	_____	_____

15. Risk register

Prioritize risks based on what could most damage or interrupt the business. Give each risk an owner and a next action.

Risk	Likelihood	Impact	Owner	Next action
_____	Low/Med/High	Low/Med/High	_____	_____
_____	Low/Med/High	Low/Med/High	_____	_____
_____	Low/Med/High	Low/Med/High	_____	_____
_____	Low/Med/High	Low/Med/High	_____	_____
_____	Low/Med/High	Low/Med/High	_____	_____

16. Monthly security review

- Critical accounts still use MFA where available.
- Former workers no longer have access.
- Important devices are updated.
- Backups completed successfully.
- A restore test was performed recently.
- New software/services were reviewed.
- Suspicious messages and incidents were reviewed.
- Security policies still match current operations.
- Critical vendors and recovery contacts are current.
- The security owner has identified the top unresolved risks.

Top unresolved risks

1. _____
2. _____
3. _____

17. 90-day security improvement roadmap

Period	Focus	Deliverables
Days 1-30	Accounts + devices	MFA, unique credentials, updates, admin review, inventory
Days 31-60	Backups + phishing	Backup test, reporting route, awareness briefing, recovery worksheet
Days 61-90	Resilience + governance	Incident plan, vendor review, risk register, monthly review

Definition of done

By day 90, the business can explain what it must protect, who has access, how important data is restored, how suspicious activity is reported, and what it would do during a security incident.

18. Final implementation checklist

- ■ Security owner assigned
- ■ Critical systems and data identified
- ■ MFA enabled on critical accounts
- ■ Password manager/authentication process adopted
- ■ Device update process established
- ■ Backup strategy documented
- ■ Restore test completed
- ■ Phishing reporting process established
- ■ Joiner/leaver process established
- ■ Incident contacts recorded
- ■ Risk register created
- ■ Monthly review scheduled

Next review date: _____

Security owner: _____

About CyberGuard

CyberGuard provides practical cybersecurity education, tools, templates, and software designed to make security easier to understand and act on.

This toolkit is an educational and operational aid. It does not provide legal, regulatory, forensic, compliance, or professional cybersecurity advice, and completing the checklist does not guarantee security.

Framework note: the structure of this toolkit is informed by the risk-management approach in NIST Cybersecurity Framework 2.0 and small-business guidance from NIST, with practical emphasis on accounts, MFA, updates, backups, phishing, access control, incident response, and recovery. NIST describes CSF 2.0 as a flexible taxonomy for managing cybersecurity risk, and its small-business guidance is specifically intended to help smaller organizations get started. CISA likewise publishes small-business resources focused on foundational controls such as phishing avoidance, passwords, MFA, software updates, logging, backups, and encryption.

CyberGuard - Practical cybersecurity for people who are not security experts.